IT and Information Security Policy

Kestrel Analytics (Pvt) Ltd

Document ID	KA-POL-04
Version	2.3
Effective date	1 July 2025
Policy owner	Information Security Office
Approved by	CEO

1. Scope

1.1 This policy applies to all employees, contractors and interns who use Company systems, devices or data.

2. Acceptable Use

2.1 Company systems are provided for business use. Limited personal use is allowed if it does not interfere with work or breach this policy.

2.2 Employees must not install unlicensed software on Company devices. Software requests are raised through the IT helpdesk.

3. Accounts and Passwords

3.1 Passwords must be at least fourteen (14) characters long and must be changed every ninety (90) days.

3.2 Login credentials must never be shared with anyone, including colleagues, Line Managers or IT staff. IT staff will never ask for your password. Sharing credentials is gross misconduct under Section 5.2 of the Code of Conduct (KA-POL-03).

3.3 Multi-factor authentication (MFA) is mandatory for email, the VPN and the HR Portal.

3.4 Accounts are locked after five (5) failed login attempts. To unlock an account, raise a ticket with the IT helpdesk.

4. Devices

4.1 Employees may use personal phones (bring your own device) only for Company email and chat, and only through the approved mobile management app. Client data must never be stored on personal devices.

4.2 USB storage devices are blocked on Company laptops by default. An exception may be requested on Form IT-SEC-2 (Removable Media Exception), must be approved by the Information Security Officer, and is valid for a maximum of thirty (30) days.

4.3 A lost or stolen Company device must be reported to the IT helpdesk (extension 4357) within two (2) hours of discovering the loss. The employee must also submit Form IT-SEC-5 (Security Incident Report) within twenty-four (24) hours.

5. Data Classification

5.1 Company data is classified into four levels: Public, Internal, Confidential and Restricted.

5.2 Restricted data includes client personal data, login credentials and source code written for clients. Restricted data must be encrypted when stored and when sent, and must never be sent from or to personal email accounts.

5.3 Sharing Confidential or Restricted data outside the Company requires approval from the Data Protection Officer.

6. Remote Access

6.1 The Company VPN must be used whenever Company systems are accessed from outside the office.

6.2 Public Wi-Fi networks (for example in cafes, hotels or airports) may be used only while connected to the VPN.

7. Security Incidents

7.1 Suspected security incidents, including phishing emails, malware and unauthorised access, must be reported to the IT helpdesk within two (2) hours.

7.2 Suspected phishing emails must be reported using the "Report Phishing" button in the email client and must not be forwarded to colleagues.

8. Data Retention

8.1 Business emails are retained for three (3) years. CCTV footage is retained for ninety (90) days. Records of personal data must be deleted when no longer needed for the purpose they were collected for.